

	SISTEMA INTEGRADO DE GESTIÓN	Código	P-O-DES-094
	PROCEDIMIENTO DE DESARROLLO SEGURO	Versión	1.0
		Vigente desde	20/10/2025
DACTA SAC	DOCUMENTO CONTROLADO	Página	1 de 5

1. OBJETIVO

Definir el proceso de realización de pruebas de seguridad en los sistemas y aplicaciones desarrolladas por la empresa, con el fin de identificar vulnerabilidades y mitigar riesgos de seguridad, garantizando la confidencialidad, integridad y disponibilidad de la información.

2. ALCANCE

Este procedimiento aplica a todos los sistemas, aplicaciones y servicios desarrollados o gestionados por la empresa, así como a las pruebas de seguridad realizadas en entornos de desarrollo, pruebas y producción.

3. RESPONSABLES

- **Oficial de seguridad de la información:** Definir las políticas y supervisar la ejecución de las pruebas de seguridad.
- **Desarrolladores:** Corregir las vulnerabilidades detectadas en las pruebas de seguridad.
- **Equipo de QA (Quality Assurance):** Coordinar y ejecutar las pruebas en entornos controlados.
- **Coordinador de TI:** Asegurar que los entornos de prueba reflejen condiciones reales sin comprometer la seguridad de producción

4. TIPOS DE PRUEBAS DE SEGURIDAD

- **Pruebas de Análisis Estático (SAST):** Revisión del código fuente en busca de vulnerabilidades de seguridad sin ejecutarlo.
- **Pruebas de Análisis Dinámico (DAST):** Evaluación del comportamiento de la aplicación en ejecución para detectar vulnerabilidades.
- **Pruebas de Penetración (Pentesting):** Simulación de ataques para identificar posibles brechas de seguridad.
- **Escaneo de Vulnerabilidades:** Uso de herramientas automatizadas para detectar fallos de seguridad en aplicaciones y sistemas.
- **Revisión de Configuración de Seguridad:** Validación de configuraciones en servidores, bases de datos y servicios para evitar malas configuraciones.

5. DOCUMENTOS DE REFERENCIAS

- ISO/IEC 27001:2022 – Gestión de Seguridad de la Información.
- OWASP (Open Web Application Security Project).
- NIST SP 800-115 – Guía de pruebas de seguridad de sistemas de información.

	SISTEMA INTEGRADO DE GESTIÓN	Código	P-O-DES-094
	PRUEBAS DE SEGURIDAD	Versión	1.0
		Vigente desde	20/10/2025
DACTA SAC	DOCUMENTO CONTROLADO	Página	2 de 5

6. PROCEDIMIENTO

N°	Actividades	Descripción	Responsable	Registros
1. PLANIFICACION DE PRUEBAS				
1.1.	Identificar los sistemas y aplicaciones a evaluar	Identificar qué aplicaciones de software, sistemas y módulos que son parte del desarrollo.	Coordinador de Desarrollo /Coordinador de Consultoría Integrens	P-O-DES-091 Ejecución de proyectos/ P-O-ACS-001 Procedimiento de Aseguramiento de la calidad de software
1.2.	Definir el alcance de las pruebas y los objetivos	Asegurar que las pruebas de seguridad sean adecuadas, relevantes y cubran todas las áreas necesarias del desarrollo	Coordinador de Desarrollo /Coordinador de Consultoría Integrens	P-O-DES-091 Ejecución de proyectos/ P-O-ACS-001 Procedimiento de Aseguramiento de la calidad de software
2. EJECUCION DE PRUEBAS				
2.1.	Seleccionar herramientas adecuadas según el tipo de prueba	- Las herramientas a utilizar para las pruebas de seguridad deben estar alineadas con los mejores estándares de la industria, las herramientas a utilizar son: - Pruebas de Análisis Estático (SAST): SONARQUBE - Pruebas de Análisis Dinámico (DAST): OWASP ZAP - Pruebas de Penetración (Pentesting): OWASP ZAP - Escaneo de Vulnerabilidades: OpenVAS - Revisión de Configuración de Seguridad: OpenVAS	Coordinador de Desarrollo/ Coordinador de Desarrollo /Coordinador de Consultoría Integrens /Coordinador de TI	Acta de Reunión

	SISTEMA INTEGRADO DE GESTIÓN	Código	P-O-DES-094
	PRUEBAS DE SEGURIDAD	Versión	1.0
		Vigente desde	20/10/2025
DACTA SAC	DOCUMENTO CONTROLADO	Página	3 de 5

N°	Actividades	Descripción	Responsable	Registros
2.2.	Realizar pruebas en un entorno controlado	- Preparación del entorno controlado - Configurar un entorno aislado de pruebas - Implementar herramientas de monitoreo y registro - Revisión de Código Fuente (Análisis Estático) - Análisis Dinámico de la Aplicación (DAST)	Desarrolladores/ Consultor Integrens/Coordinador de TI	Herramientas de análisis
2.3.	Documentar los hallazgos de seguridad y evidencias	- Una vez que hayas realizado las pruebas de seguridad (ya sea análisis estático, dinámico, pentesting, etc.), es fundamental capturar cada hallazgo de manera clara y detallada. - Es fundamental proporcionar evidencias claras de que las pruebas fueron realizadas y de cómo se identificaron los hallazgos. Las evidencias también sirven como respaldo durante la auditoría y en futuras revisiones	Desarrolladores / Consultor Integrens/Coordinador de TI	Informes de los análisis de las herramientas
3. ANALISIS Y REPORTE DE RESULTADOS				
3.1.	Analizar los resultados y clasificar las vulnerabilidades según su criticidad	Al finalizar la revisión del código fuente (Análisis Estático) la herramienta nos muestra indicadores de seguridad (Confiabilidad, Duplicados, Cobertura por pruebas unitarias, etc) con la debida descripción de los mismos, así como propuestas de mejora.	Desarrolladores/ Consultor Integrens	Herramientas de análisis
3.2.	Elaborar un informe detallado con los hallazgos y recomendaciones de mitigación	Recopilar materia visual de los resultados obtenidos luego de la realización de los análisis del código (AS-IS).	Desarrolladores/ Consultor Integrens	Informes de los análisis de las herramientas
4. CORRECCION Y VALIDACION				
4.1.	Coordinar con los desarrolladores y equipos técnicos la remediación de vulnerabilidades	- Análisis Estático: - Aplicar las recomendaciones propuestas por las herramientas de análisis de código o proponer mejoras basadas en los documentos de referencia de este procedimiento. - Análisis Dinámico:	Desarrolladores/ Consultor Integrens	

	SISTEMA INTEGRADO DE GESTIÓN	Código	P-O-DES-094
	PRUEBAS DE SEGURIDAD	Versión	1.0
		Vigente desde	20/10/2025
DACTA SAC	DOCUMENTO CONTROLADO	Página	4 de 5

N°	Actividades	Descripción	Responsable	Registros
		○ Reportar los hallazgos al Equipo de desarrollo para la realización de las correcciones correspondientes. ○ Aplicar mejoras basadas en los resultados obtenidos.		Herramienta de control de proyectos
4.2.	Volver a ejecutar pruebas para verificar la efectividad de las correcciones.	● Repetir desde el punto 2.2	Desarrolladores/ Consultor Integrens/Coordinador de TI	
4.3.	Validar la implementación de medidas de mitigación antes del despliegue	● Verificar los informes de resultados obtenidos luego de la realización de los análisis del código.	Coordinador de Desarrollo/Coordinador de Consultoría Integrens	Informes de los análisis de las herramientas
5. MONITOREO Y MEJORA CONTINUA				
5.1.	Registrar y hacer seguimiento a los hallazgos de seguridad	● Realizar revisiones mensuales de los proyectos que han sido analizados y validar los indicadores de seguridad.	Equipos de Desarrollo y Testing	Acta
5.2.	Revisar y actualizar el procedimiento de pruebas periódicamente	● Realizar revisión anual, o ante de requerimiento de cambios, del procedimiento de pruebas de seguridad y, de ser el caso, realizar actualizaciones al mismo.	Equipos de Desarrollo y Testing	Procedimiento de pruebas de seguridad
5.3.	Capacitar al equipo en buenas prácticas de seguridad	● Semestralmente, realizar capacitaciones a los equipos de desarrollo y testing acerca de buenas prácticas de seguridad en el ciclo de vida de desarrollo de software.	Equipos de Desarrollo y Testing	Acta

	SISTEMA INTEGRADO DE GESTIÓN	Código	P-O-DES-090
	PLANEAMIENTO DE PROYECTOS	Versión	1.0
		Vigente desde	20/10/2025
DACTA SAC	DOCUMENTO CONTROLADO	Página	5 de 5

7. HERRAMIENTAS RECOMENDADAS

- SAST: SonarQube
- DAST: OWASP ZAP, Burp Suite
- Pentesting: Metasploit, Kali Linux
- Escaneo de Vulnerabilidades: Nessus, OpenVAS
- Revisión de Configuración: CIS Benchmarks, Lynis

8. REGISTROS

- . Informes de los análisis de las herramientas

9. ANEXOS

N.A.

10. CONTROL DE CAMBIOS

Versión	Fecha	Descripción	Elaborado por	Elaborado por	Revisado por	Aprobado por
1	20/10/2025	Emisión	Coordinador de Desarrollo	Coordinador de Consultoría Integrens	Gerente de Proyectos	Gerente General
2						
Firmas de la versión vigente						
			A. Morales	M. Molina	S. Rafaile	G. Rafaile
Identificación de las modificaciones						
Versión			Descripción de cambios			